

PENETRATION TESTING ASSESSMENT REPORT

Session Hijacking via Cookie Injection

Prepared by:	Muhammad Adeel Tariq
Certification:	CEH (EC-Council) Certified
Training Program:	NAVTTTC-funded Cybersecurity Training, Corvit Institute, Rawalpindi
Classification:	Educational / Controlled Lab Environment

EXECUTIVE SUMMARY

This assessment demonstrates session hijacking by extracting a session cookie from an authenticated browser session and injecting it into a separate, unauthenticated browser instance, resulting in unauthorized account access without credentials. Screenshots in this report have been redacted to remove personally identifiable information (names and photos) unrelated to the technical demonstration.

SCOPE

Test Target:	Facebook (session/cookie handling, lab context)
Browsers Used:	Firefox (Browser A), Chrome (Browser B)
Tool Used:	Cookie-Editor (browser extension)

Task: Session Hijacking Using Cookie Editor

Objective:

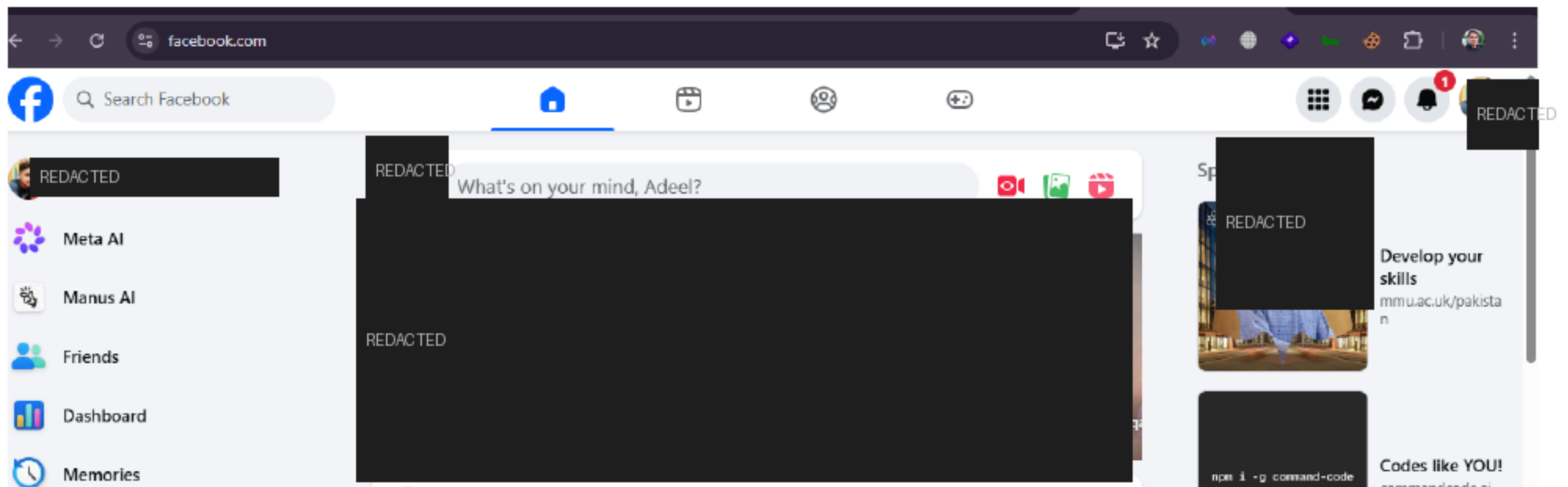
To demonstrate session hijacking by extracting a session cookie from one browser, injecting it into another browser, and gaining unauthorized access without credentials.

Tools Used:

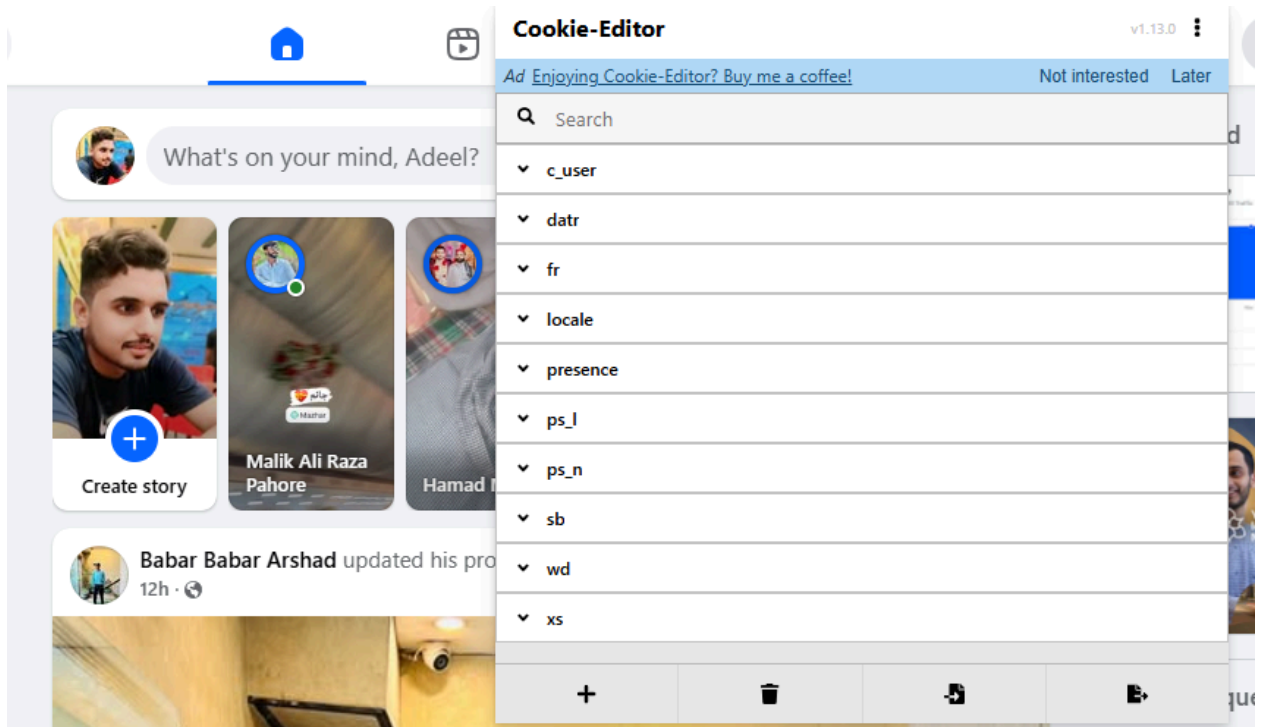
- Cookie Editor (browser extension)
- Facebook (test target in lab environment)
- Two browser instances: Firefox (Browser A) & Chrome (Browser B)

Steps Performed:

- Login to Facebook using Browser A (Firefox) with valid credentials.



- Extracted session cookies using Cookie Editor extension.



- Copied the session cookie value (including c_user, xs, datr, etc.).
- Opened Browser B (Chrome) – fresh session, no login.

< Log in to Facebook

Email address or mobile number

Password

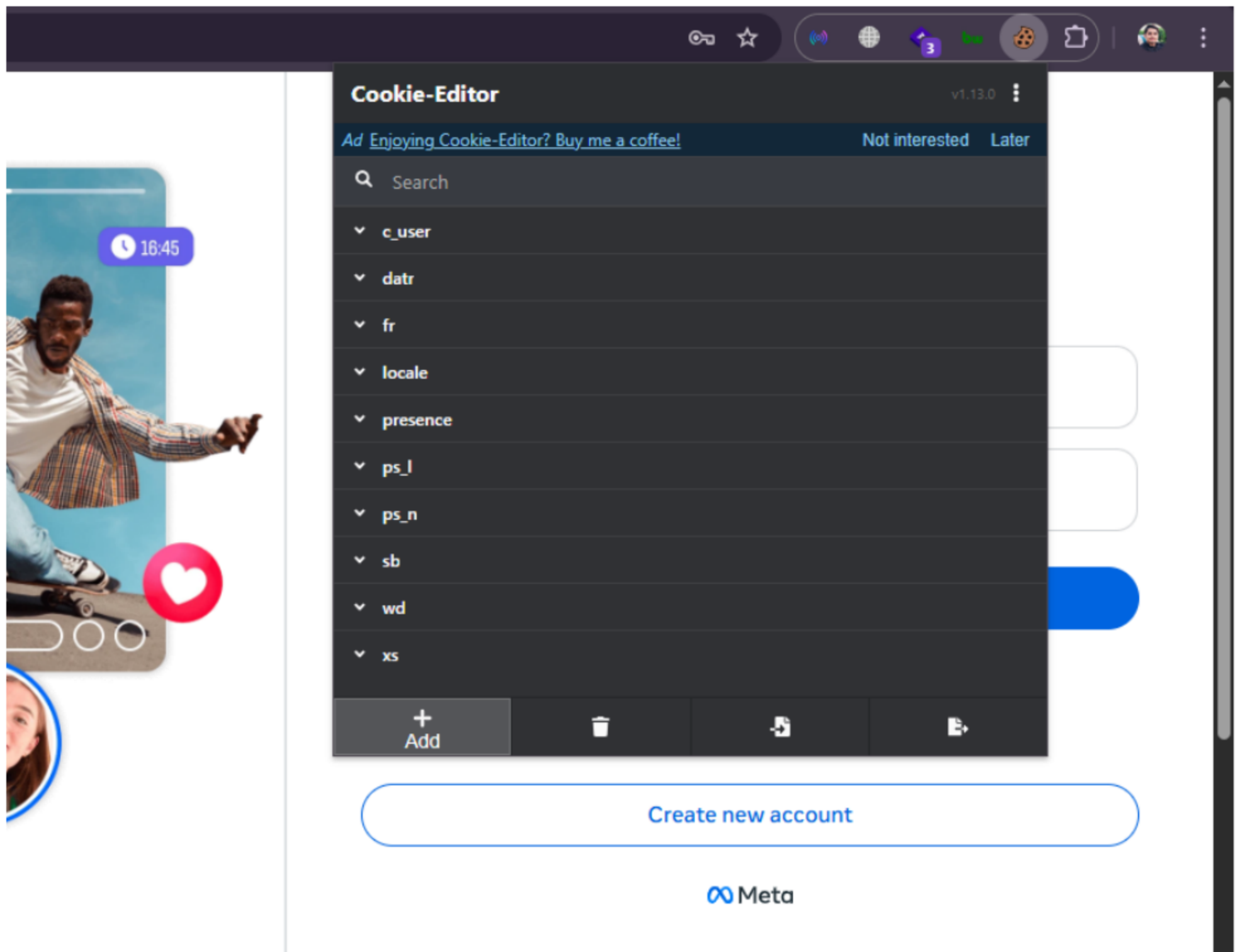
Log in

Forgotten password?

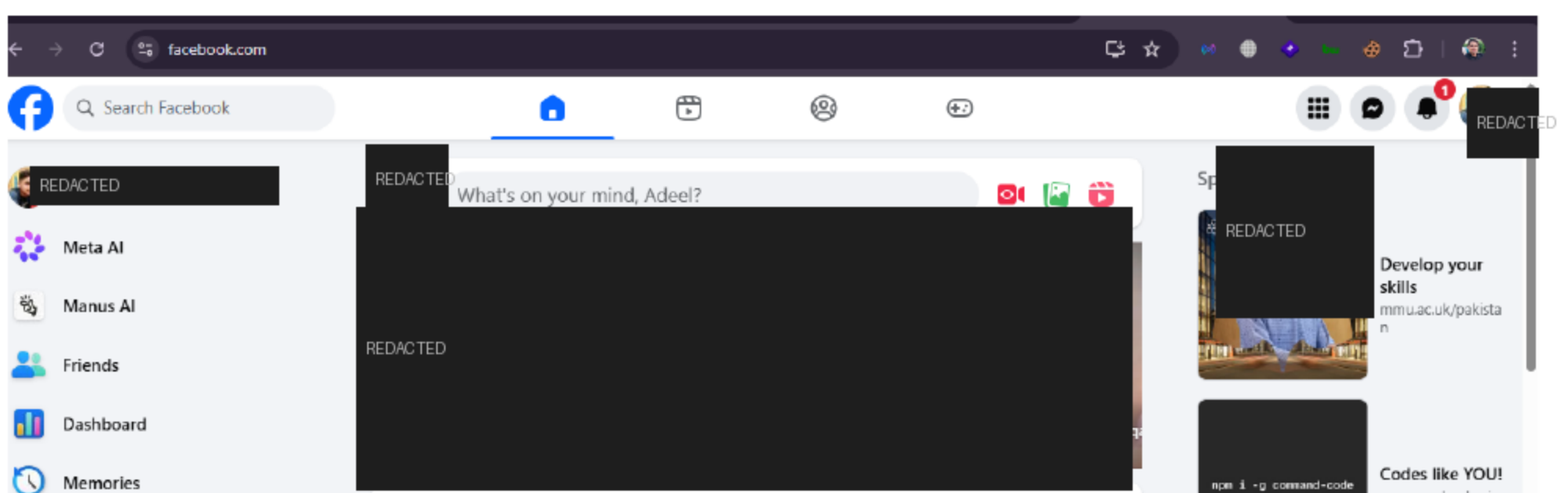
Create new account

 Meta

- Injected the copied cookies into Browser B using Cookie Editor.



- Refreshed the Facebook page – automatic login into the same account without password.



Outcome:

✓ Session hijacking was successful.

Browser B gained full access to the victim's Facebook account without any authentication prompt.

What security controls can prevent session hijacking attacks like this?

Answer:

- HttpOnly Flag – Prevents JavaScript from accessing cookies.
- Secure Flag – Cookies are only sent over HTTPS connections.
- SameSite Flag – Cookies are not sent on cross-site requests.
- Session Timeout – Session expires after a short period of inactivity.
- IP Binding – Links the session ID to the user's IP address.
- MFA (Multi-Factor Authentication) – Requires a second factor even if cookie is stolen.

Session Hijacking Using Cookie Editor

Vulnerability Classification

CWE-384: Session Fixation / Insecure Session Cookie Handling

What I Learned

A session cookie alone is sufficient to fully impersonate an authenticated user, with no password required — this demonstrated why cookie confidentiality and scope restrictions (HttpOnly, Secure, SameSite) are as critical to account security as the login mechanism itself.

Remediation Recommendations (as documented)

- HttpOnly Flag — prevents JavaScript from accessing cookies
- Secure Flag — cookies are only sent over HTTPS connections
- SameSite Flag — cookies are not sent on cross-site requests
- Session Timeout — session expires after a short period of inactivity
- IP Binding — links the session ID to the user's IP address
- MFA (Multi-Factor Authentication) — requires a second factor even if a cookie is stolen

Environment Disclaimer

This demonstration was performed on the author's own account, across two browser instances under the author's own control, as part of structured cybersecurity training. No third-party accounts or systems were accessed. Screenshots have been redacted to remove personal names and photos unrelated to the technical demonstration.